

3 さくらのクラウドでのアーキテクチャ設計

3.2 セキュリティの設計

3.2 セキュリティの設計

3.2.1 リソースのセキュリティ

3.2.1 リソースのセキュリティ

学習目標とアウトライン

学習目標

- クラウド環境におけるリソースのセキュリティの基本的な考え方を学び、セキュリティリスクに対応する方法を理解する
- さくらのクラウドで提供されるリソースのセキュリティに関連する機能、サービス、および選択可能なネットワーク構成を理解する

【キーワード】

会員IDとプロジェクト
プリンシパル
IAMポリシー
IDポリシー
ロール

認証方式
(2要素認証、シングルサインオン、
ユーザープロビジョニング)
サーバアクセスのセキュリティ
(SSH・RDP)
イベントログ

アウトライン

a. さくらのクラウドにおける認証とアクセス管理について理解する

- さくらのクラウドにおける認証
- さくらのクラウドにおけるアクセス管理

b. 基本的なアクセス権を付与することを検討する

- プロジェクトとユーザの利用
- シングルサーバコントロールパネルの利用

アウトライン

c. ログを取得する

- ログの取得と保管

d. サーバアクセスにおけるセキュリティに配慮する

- サーバアクセス手段の検討

3.2.1 リソースのセキュリティ

さくらのクラウドにおける認証

会員ID

会員IDについて

- **さくらインターネットのサービスを申し込む際、利用者ごとに一意に付与されるID**
 - アルファベット3文字と数字5文字で構成(例:nnn12345)
 - 会員IDはサービスの利用に重要な情報。会員ごとにユニークであり、利用者の個人情報に相当する。第三者に共有せず安全な場所に保管する
- **会員IDは管理者権限が付与されている**
- **会員IDでログインすると、会員IDを使って作成した全てのプロジェクトにアクセスすることが可能**

プロジェクト

プロジェクトについて

- プロジェクトはリソースの作業空間を表す
- リソースの管理と請求処理は、プロジェクトごとに区分される

クラウドユーザ

クラウドユーザについて

- クラウドユーザ（ユーザ）はリソースを操作するために用いられる
- リソースを操作する社員やメンバーごとにユーザを作成する

ユーザグループ

ユーザグループについて

- ユーザをグループ化し、ユーザグループごとにアクセス権限のコントロールをする機能
- グループに所属する全ユーザにまとめて権限を適用できる

サービスプリンシパル

サービスプリンシパルについて

- システムやアプリケーションがAPIにアクセスするための認証手段
- 主に自動処理やシステム連携などの用途で利用する

操作する主体	認証手段	使う場面
人	ユーザ	管理画面やCLIの操作など
システム	サービスプリンシパル	サービス間のAPI連携

プロジェクトと権限管理の仕組み

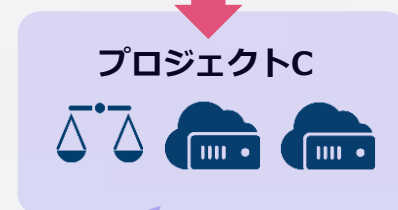


さくらのクラウドコントロールパネル



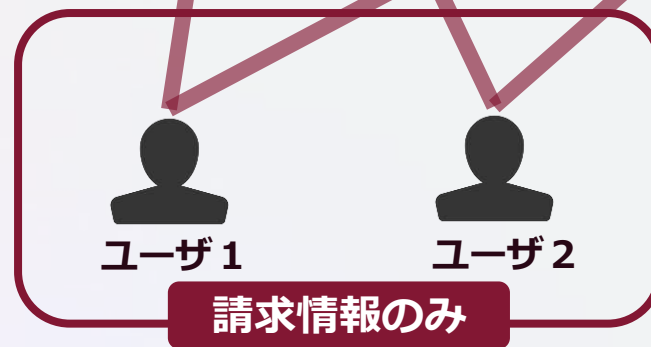
会員 ID でログインすると、
全てのプロジェクト
(リソース利用と請求の単位)
にアクセス可能

顧客・案件・
プロジェクトごとに作成。
リソースと請求を
プロジェクトごとに分けられる

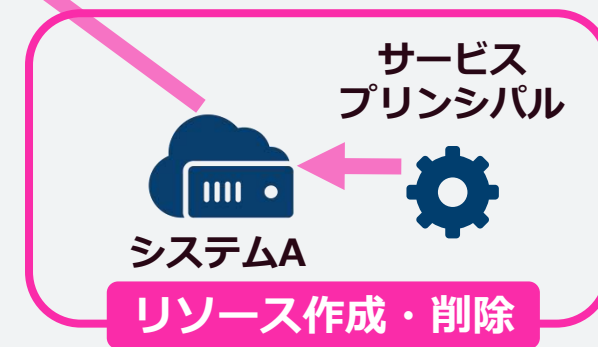


社員やメンバーごとにユーザを作成し、各々の役割に応じ権限やアクセス可能なリソースを割り当て

グループを利用することでユーザへの権限を一括設定できる



サービスプリンシパルで
システムに権限を割り当て



プリンシパル

【Tips】

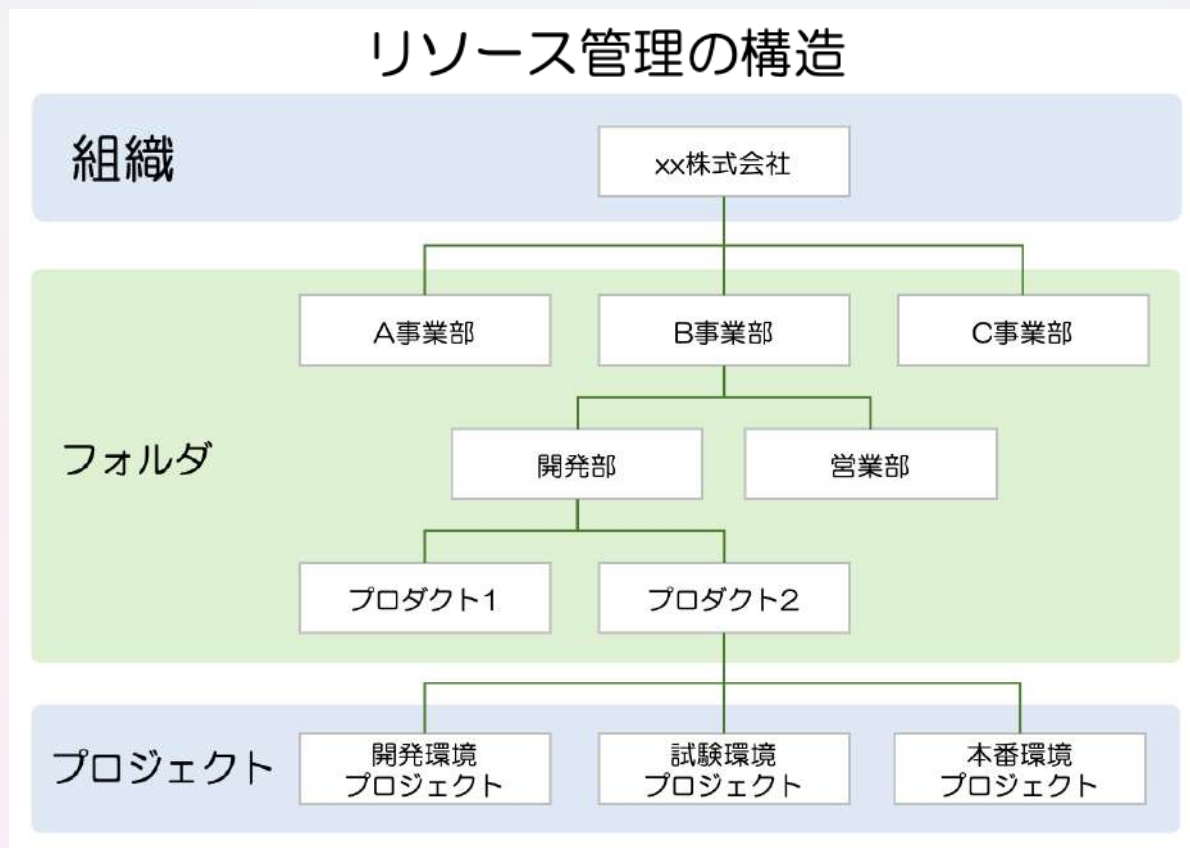
プリンシパル（Principal）とは

プリンシパルは、「誰が操作を実行するか」を表す概念です。
さくらのクラウドでは、ユーザ・グループ・サービスプリンシパルの三種類を指します。

リソース管理機能

リソース管理機能について

- 組織>フォルダ>プロジェクトという階層でリソースを柔軟に管理できる



組織 (Organization)

- 所属組織（会社名など）を表すリソース階層のルートノード

フォルダ (Folder)

- プロジェクトを階層的に分類・整理するためのリソース

リソースID

【Tips】

リソースIDについて

さくらのクラウドにおける認証とは関係ありませんが、リソースIDについても覚えておきましょう。

リソースIDは、さくらのクラウド上で各リソースに一意に付与される12桁の数字です。
請求やメンテナンスの通知、サポートへの問い合わせ時に、対象のリソースを特定する際に使用します。

3.2.1 リソースのセキュリティ

さくらのクラウドにおける アクセス管理

アクセスレベル

アクセスレベルについて

- **プリンシパルの組み合わせごとにコントロールパネルやAPIでの操作範囲を制限することができる**
 - ユーザの役割に応じたアクセスレベルを設定することにより、利便性やセキュリティを向上させることができる
 - APIキーに関しては、プロジェクトごとに作成されたAPIキーに対してアクセスレベルを設定することができる

アクセスレベル

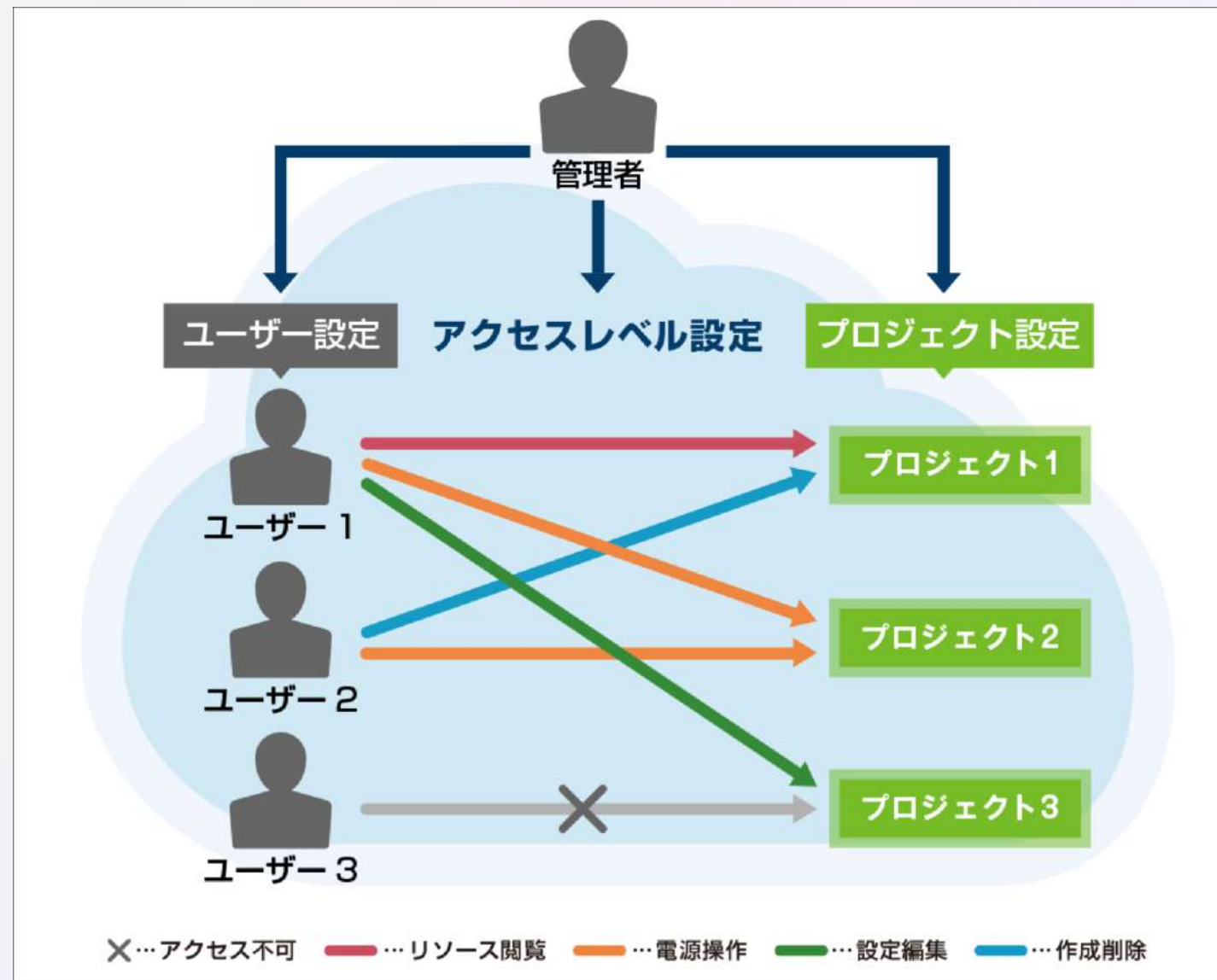
アクセスレベルと操作権限

- さくらのクラウドでは、リソース操作に関わる権限を制限することが可能。閲覧や設定の編集等、複数の権限レベルが用意されている
- 操作権限は以下の4段階に分かれており、数値の大きな権限レベルほど、より小さな権限を包含している

権限レベル	対象プロジェクト内で許可される操作
1. リソース閲覧	・ リソース閲覧
2. 電源操作	・ サーバ/アプライアンスの電源操作 ・ サーバのリモートコンソール操作
3. 設定編集	・ 請求金額の増減が発生しないリソースの作成/削除操作 ・ 作成済みのリソースの設定変更
4. 作成・削除	・ 請求金額が増減する作業を含めた全ての操作 ・ APIキーの発行/参照

アクセスレベル

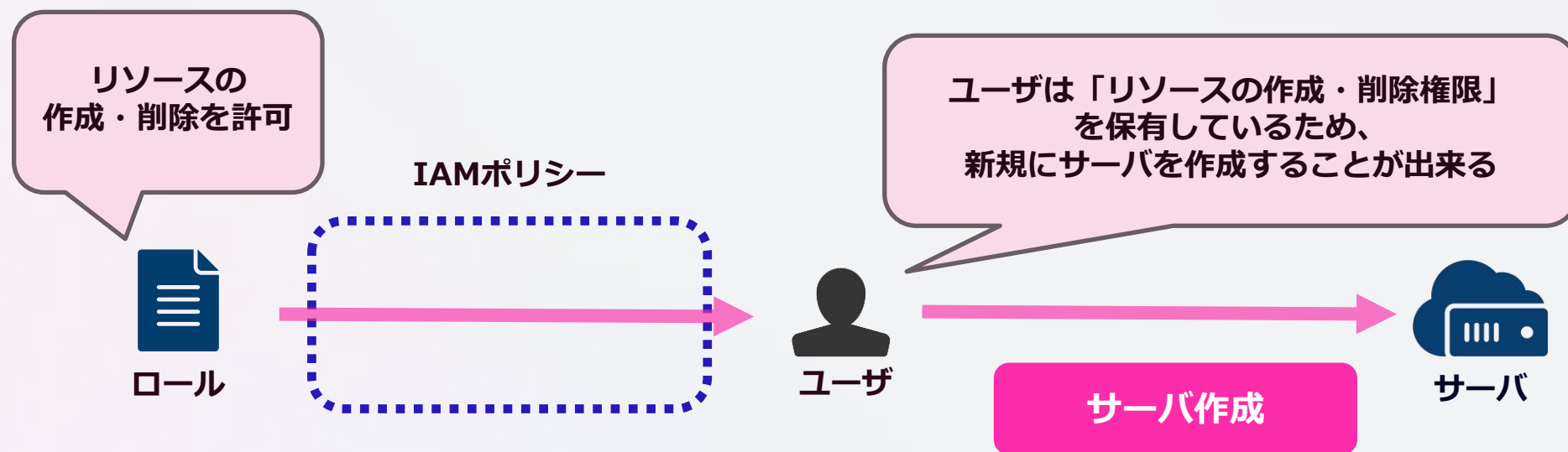
アクセスレベルと操作権限



IAMポリシー

IAMポリシーについて

- さくらのクラウドにおけるリソースへのアクセス制御を定義するためのルール
 - プリンシパルに対して「何ができるか」「どのリソースに対して操作できるか」を明示的に指定することで、利便性やセキュリティを向上できる
 - 個別のアクセス権限をひとまとめたものをロールと呼ぶ



IAMポリシー

ロールについて

- さくらのクラウドにおいて、リソース操作に関するロールは以下の操作を実行できる

ロール	対象プロジェクト内で許可される操作
KMS管理者	・ KMSの全操作
クラウドHSM管理者	・ クラウドHSMの全操作
シークレットマネージャ管理者	・ シークレットマネージャの全操作
リソース閲覧	・ リソース閲覧
電源操作	・ リソース閲覧で許可される全ての操作 ・ サーバ/アプライアンスの電源操作
設定編集	・ 電源操作で許可されるすべての操作 ・ 請求金額の増減が発生しないリソースの作成/削除操作 ・ 作成済みのリソースの設定変更
作成・削除	・ 請求金額が増減する作業を含めた全ての操作 ・ APIキーの発行/参照

IAMポリシー

ロールについて

- 請求情報とイベントログの閲覧、オブジェクトストレージ、さくらのウェブアクセラレータ、さくらの専用サーバ PHY、AppRun、高火力 DOK、APIゲートウェイ、ワークフローの各コントロールパネルへのアクセス権限は、以下のロールで付与できる

権限名	許可される操作
請求閲覧権限	プロジェクトの請求情報の参照
オブジェクトストレージ	オブジェクトストレージへのアクセス
さくらのウェブアクセラレータ	さくらのウェブアクセラレータへのアクセス
さくらの専用サーバ PHY	さくらの専用サーバ PHY へのアクセス
AppRun	AppRun へのアクセス
高火力 DOK	高火力 DOKへのアクセス
APIゲートウェイ	APIゲートウェイへのアクセス
ワークフロー	ワークフローへのアクセス
イベントログ	イベントログの参照

IAMポリシー

ロールについて

- ・ オwnerロールでは以下の操作を実行できる

ロール	対象プロジェクト内で許可される操作
オーナー	・ プロジェクトを管理する権限 ・ 請求金額が増減する作業を含めた全ての操作 ・ APIキーの発行/参照 ・ プロジェクトの削除 ・ プロジェクトへのIAMポリシーの設定・更新

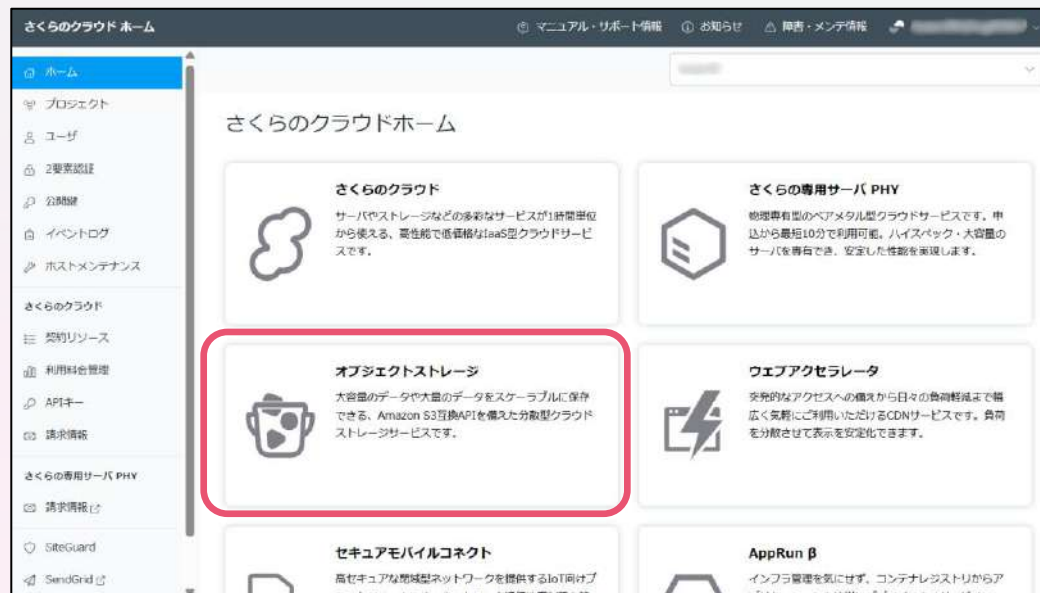
- ・ セキュリティコントロールに関するロールでは以下の操作を実行できる

ロール	対象プロジェクト内で許可される操作
セキュリティコントロール管理者	すべての設定・評価・チケット・自動アクションを含む全操作の管理・更新が可能
セキュリティコントロール運用者	設定変更は限定され、参照＋一部運用（チケット更新など）が可能
セキュリティコントロール閲覧者	全項目の参照のみが可能
セキュリティコントロールエージェント	セキュリティコントロールの 内部処理用（自動付与）

IAMポリシー

IAMポリシーと各機能へのアクセス権限

- IAMポリシーでアクセスが許可されていない場合、コントロールパネルに表示されているアイコンをクリックしても、権限不足でエラーが表示される



オブジェクトストレージへのアクセスが許可されていない場合の表示



アクセス権限エラー

ご利用中のユーザはオブジェクトストレージへのアクセス権限がありません。
アクセス権限のあるユーザで再度お試しください。

閉じる

IAMポリシー

コントロールパネル操作について

- IAMポリシーの設定は、コントロールパネルのホーム画面にある「IAMポリシー」メニューから行うことができる(次ページ①)。APIキーのアクセスレベルの設定は「APIキー」メニューから行うことができる(次ページ②)
- IAMポリシーおよびアクセスレベルの設定は、会員IDを使用してコントロールパネルにログインした際に行える



さくらのクラウド ホーム

② マニュアル・サポート情報 ① お知らせ ⚠ 障害・メンテナンス

ホーム
プロジェクト
ユーザ
ユーザグループ
IAMポリシー
サービスプリンシパル
公開鍵
SSOプロファイル
イベントログ
ホストメンテナンス
さくらのクラウド
契約リソース
最適化サジェスト
利用料金管理
APIキー
請求情報
サービス間接続申し込み

アクセス IAMポリシーの設定

アクセス権を付与できます。詳細は[IAMポリシーのマニュアル](#)をご覧ください。

ⓘ アクセス権付与後、各プリンシパルに反映されるまでに最大3分かかります。

プロジェクト	プリンシパル	ロール
	ユーザ /	
	ユーザ /	
	ユーザ /	
	ユーザグループ /	
	サービスプリンシパル /	

IAMポリシーを適用するプリンシパルを選択

作成のロールに追加されます。

キャンセル 作成

The screenshot shows the 'IAMポリシー' (IAM Policy) configuration page in the Sakura Cloud console. The left sidebar contains navigation links: ホーム, プロジェクト, ユーザ, ユーザグループ, IAMポリシー (highlighted), サービスプリンシパル, 公開鍵, SSOプロファイル, イベントログ, ホストメンテナンス, さくらのクラウド, 契約リソース, 最適化サジェスト, 利用料金管理, APIキー, 請求情報, and サービス間接続申し込み. The main content area is titled 'プロジェクト' and has sections for 'プリンシパル' and 'ロール'. The 'プリンシパル' section has a search bar with filters for 'ユーザ', 'ユーザグループ', and 'サービスプリンシパル'. Below it is a text instruction: 'ユーザ、ユーザグループ、サービスプリンシパルの中から、ロールを付与するプリンシパルを選択してください。'. The 'ロール' section has a dropdown menu currently showing 'さくらのクラウド'. A red box highlights this dropdown and the list of roles below it: '請求閲覧', 'オブジェクトストレージ', 'ウェブアクセラレータ', 'さくらの専用サーバPHY', 'AppRun β', '高火力 DOK', 'APIゲートウェイ', 'ワークフロー', and 'イベントログ'. Another red box highlights the '操作権限' (Operation Permissions) section, which lists 'リソース閲覧', '電源操作', '設定編集', and '作成・削除'. A third red box highlights the '各機能へのアクセス権限' (Access Permissions for Each Function) section, which is currently empty. A fourth red box points to the 'プリンシパルに付与するロールを選択' (Select role to grant to principal) instruction. The top navigation bar includes links for 'マニュアル・サポート情報', 'お知らせ', and '障害・メンテナンス情報'.

さくらのクラウド ホーム

プロジェクト

プリンシパル

ユーザ / ユーザグループ / サービスプリンシパル

ユーザ、ユーザグループ、サービスプリンシパルの中から、ロールを付与するプリンシパルを選択してください。

ロール

さくらのクラウド

請求閲覧

オブジェクトストレージ

ウェブアクセラレータ

さくらの専用サーバPHY

AppRun β

高火力 DOK

APIゲートウェイ

ワークフロー

イベントログ

リソース閲覧

電源操作

設定編集

作成・削除

操作権限

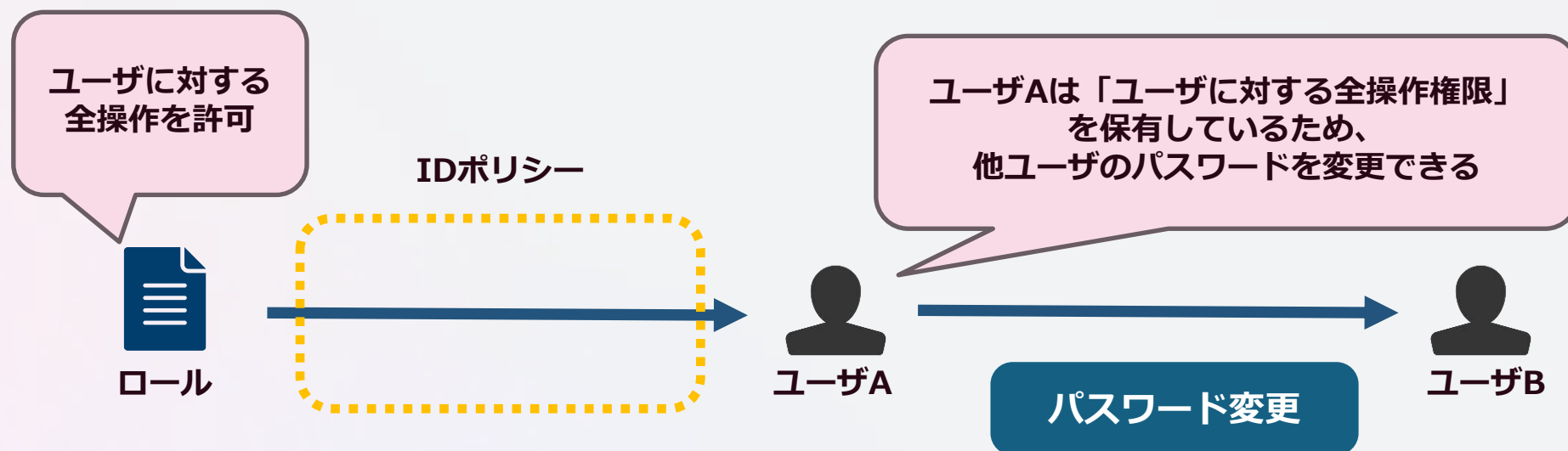
プリンシパルに付与するロールを選択

各機能へのアクセス権限

IDポリシー

IDポリシーについて

- さくらのクラウドにおけるユーザやグループへのアクセス制御を定義するためのルール
 - プリンシパルに対して、ID管理・認証・権限設計に関する操作を明示的に指定することで、権限管理の一貫性とセキュリティを向上できる
 - パスワード変更といった、ユーザ操作権限の付与に利用する



IDポリシー

ロールについて

- ・ さくらのクラウドにおいて、ユーザやグループに関するロールは以下の操作を実行できる

ロール	許可される操作
ID管理者	・ ユーザに対する全操作 ・ ユーザの2要素認証の操作（ワンタイムパスワード、セキュリティキーの登録を除く） ・ ユーザグループに対する全操作 ・ IDポリシーに対する全操作 ・ SSOプロファイルの設定 ・ ユーザープロビジョニングの設定 ・ 認証設定（パスワードポリシー、認証条件）
ID閲覧者	・ ユーザの取得 ・ ユーザグループの取得

3.2.1 リソースのセキュリティ

プロジェクトとユーザの利用

プロジェクト分割の検討

検討にあたっての考慮事項

- **利用者が提供するサービスや開発プロジェクトごとにプロジェクトを分けることにより、利用できるリソースを制限し、セキュリティを強化できる**
 - これにより、異なるプロジェクトのリソース間で相互に接続できない構成を実現する
 - 異なるプロジェクトのリソース間で通信させる必要がある場合には、ローカルルータの利用を検討する
- **開発から本番リリースまでのライフサイクルをプロジェクトごとに分け、運用効率とリスク低減を実現する**
 - 環境ごとにフォルダやプロジェクトを分けることで、本番環境への意図しない変更を防ぎ、テスト資源の影響を受けない安全な構成を実現する

アクセスレベルの検討

検討にあたっての考慮事項

- **利用者の役割に応じて、各ユーザには基本的なアクセスレベルを設定する**
 - ユーザごとに、各プロジェクトに対するリソース操作のアクセスレベルを設定する。
さらに、利用するサービスに応じて、ユーザごとに各コントロールパネルへのアクセス権限を設定する
 - ユーザグループを利用すると、同様の権限を所属する複数のユーザに一括で設定可能で、利便性やセキュリティを向上することができる
- **ユーザが複数のグループに所属する場合には、利用者の意図した通りに権限が適用されているか確認する**
 - リソース操作のアクセスレベルは「より強い権限」が優先して適用され、各コントロールパネルへのアクセス権限は「許可した権限の足し合わせ」になることに注意する

アクセスレベルの検討

検討にあたっての考慮事項

- 会員IDは、以下に挙げる必要な場合にのみ使用し、通常のアクセス制御やリソース操作にはユーザを使用する
 - プロジェクトの作成
 - イベントログでコントロールパネルへのログイン履歴の確認
 - サービス間接続の申し込み
- (次ページへ続く)

アクセスレベルの検討

(前ページからの続き)

- ローカルルータに関する以下の操作
 - ハイブリッド接続のローカルルータ作成
 - 専用サーバPHY/さくらのVPS等における各サービス内のスイッチへの接続/切断操作
- 会員情報の変更、支払方法の変更 など

【Tips】

会員IDの設定変更

会員IDの設定変更は会員メニューから行います。
コントロールパネルからは変更できませんので、注意してください。

会員IDを使用したログイン

セキュリティ上の理由により、さくらのクラウド内のネットワークからは、
会員IDを使用したコントロールパネルへのログインが制限されています。

認証方式の検討

検討にあたっての考慮事項

- 会員ID、およびユーザの認証方式として、通常のパスワード認証に加え、2要素認証を利用できる。これにより、認証経路を複数化し、セキュリティを強化する
 - 2要素認証を有効化すると、ユーザ名とパスワードの組み合わせによるコントロールパネルへのログインに加え、FIDO2対応デバイスを用いるセキュリティキーの登録もしくは一般的なTOTP方式によるワンタイムパスワードの入力が必須となる。そのため、パスワードが第三者に漏洩したり、パスワード攻撃を受けた際に不正ログインされるリスクを軽減することができる
 - 会員IDでのログインについては2要素認証の利用が必須となっている。一方、クラウド上のユーザ認証方式は任意で設定できる

認証方式の検討

検討にあたっての考慮事項

- 以下の情報も参考に、求めるセキュリティと利便性に応じて、ユーザ認証で2要素認証を有効化するかどうかを検討する
 - ユーザのパスワードは、パスワードポリシーを設定することで「8文字以上64文字以内の半角英数字」に加えて、大文字/小文字/記号を含むよう定義できる
 - 認証条件を設定することで、送信元IPアドレスやログイン期間などを制御できる
 - ユーザロックアウト機能により、所定の時間内に連続して既定の回数以上パスワードの入力を間違えた場合、一定時間ログインができなくなる
 - 2要素認証を利用するために
 - ワンタイムパスワードを利用する場合、QRコード読み取り機能を備えたTOTP認証アプリケーションがインストールされたデバイス（スマートフォン等）が必要となる
 - セキュリティキーを利用する場合、FIDO2対応デバイスが必要となる

認証方式の検討

検討にあたっての考慮事項

【Tips】

TOTP方式による認証について

TOTP（Time-based One-Time Password）方式とは、事前に提供される秘密鍵と現在の時刻に基づいて生成されるワンタイムパスワードを用いた認証方式のことです。

さくらのクラウドでは、一般的なスマートフォン向けTOTP認証アプリケーションとしGoogle Authenticator や Authy を使った2要素認証の動作を確認済みです。

認証方式の検討

検討にあたっての考慮事項

【Tips】

FIDO2対応デバイスについて

「FIDO（ファイド：Fast IDentity Online）とは、非営利団体の「FIDO Alliance」がパスワードに依存しない新しいオンライン認証技術の標準化を目指して策定および普及している認証技術です。

FIDO2 に対応したデバイスを用いることで、フィッシングやパスワード漏えいのリスクを低減しつつ、利便性と高いセキュリティを両立することができます。

シングルサインオン（SSO）連携機能

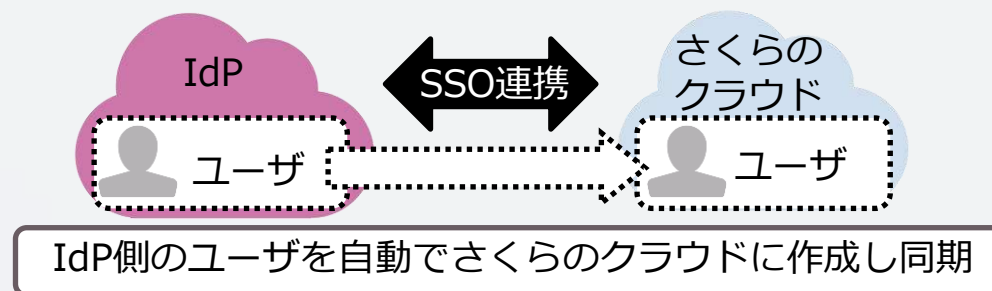
- シングルサインオン（SSO）連携を有効化し、SAML 2.0準拠の外部IdPと連携することで、さくらのクラウドへの認証の一元管理を可能とする
 - シングルサインオン（SSO）は、一度の認証で複数のサービスへのログインを可能にする仕組み。さくらのクラウドでは外部IdP（Google Workspaceなど）とSAML 2.0で連携し、管理画面を含む各種リソースへのアクセスを一元化できる。これによりログインの手間を削減し、管理者は認証運用を効率化かつ安全に実施できる
- SSO認証が有効となるのは、メールアドレスが登録されているクラウドユーザのみ
 - メールアドレスが未登録のユーザについてはSSO認証されず、さくらのクラウドのユーザ情報（2要素認証やパスワード）を使ってログインする



IdP側の認証情報を使ってさくらのクラウドにログイン

ユーザープロビジョニング機能

- ユーザープロビジョニングを有効化し、外部IdP（Microsoft Entra IDなど）と連携することで、外部IdPで一元管理されているユーザやグループの情報をさくらのクラウドへ自動反映することが可能になる
 - ユーザープロビジョニングは、IdPで追加・変更・削除されたユーザ情報をクラウドに同期し、ユーザ管理の運用を自動化する仕組みで、これによりクラウド側での手動によるユーザ登録や更新作業が不要となり、アカウントのライフサイクル管理を効率的かつ整合性のある形で実施できる
- 同期によって作成されたクラウドユーザはパスワードを保持せず、同一IdPとのシングルサインオン（SSO）による認証でログインする。また、ユーザグループもIdPからの情報をもとに連携され、さくらのクラウド上のグループ単位でのアクセス制御や権限設定を簡素化することが可能となる



3.2.1 リソースのセキュリティ

シングルサーバコントロール パネルの利用

シングルサーバコントロールパネルの利用

シングルサーバコントロールパネルについて

- 管理者がサーバ1台ごとに個別に制御するだけの権限を持ったAPIキーを発行し、利用者がそのAPIキーを使用してログインすると、対象のサーバ1台だけの操作を可能とする機能を持ったコントロールパネル
 - このコントロールパネルを利用すると、保守委託先の外部業者によるメンテナンス用、学校における学生への演習用など、ユーザ・プロジェクトをそれぞれ発行するよりも手軽に、コンソール画面操作や電源操作などサーバ1台を操作する上で最小限の機能と操作権限を備えたコントロールパネル環境を提供することが可能

シングルサーバコントロールパネルの利用

シングルサーバコントロールパネル

- シングルサーバコントロールパネルで操作可能な機能は、リソース閲覧とサーバ操作のみ。サーバ操作は、電源操作とリモートコンソール操作が許可される。必要に応じて利用することを検討する。

【Tips】

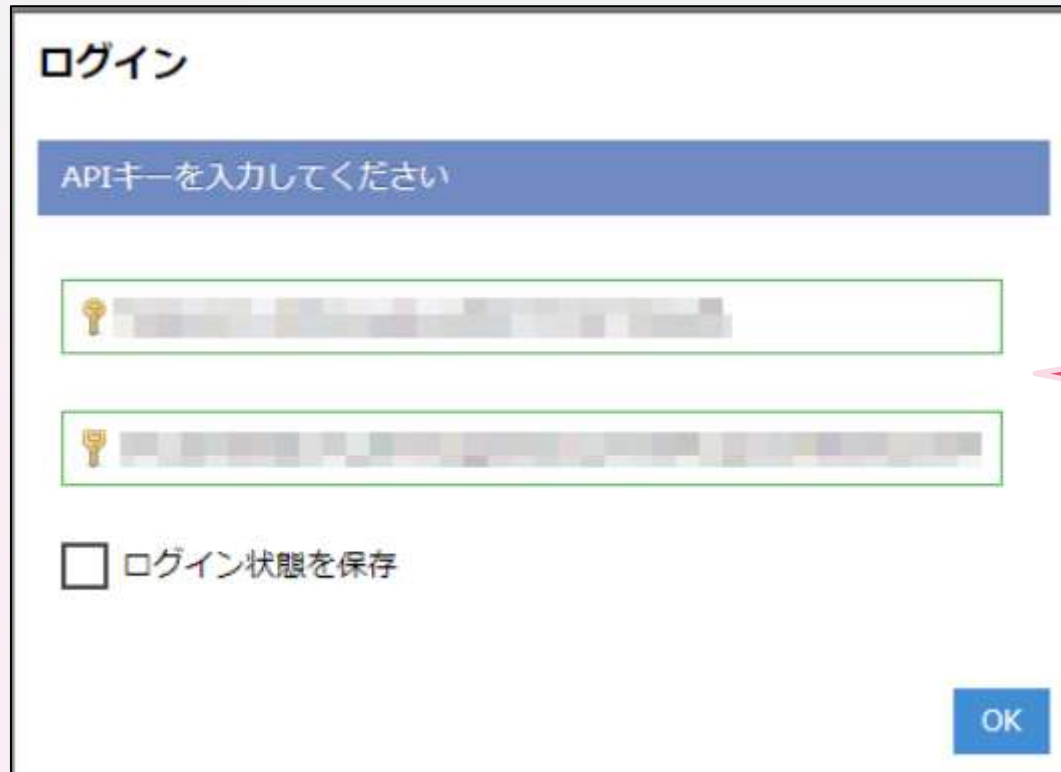
シングルサーバコントロールパネルのAPIキー

「シングルサーバAPIキー」というAPIキーの種類を設定し、アクセスレベルと紐付け先サーバを設定することにより、シングルサーバコントロールパネルを利用するためのAPIキーを発行することが可能です。

シングルサーバコントロールパネルの利用

シングルサーバコントロールパネル

ログイン画面



The screenshot shows a login window titled "ログイン" (Login). At the top, a blue bar contains the text "APIキーを入力してください" (Please enter the API key). Below this are two input fields, each preceded by a key icon, representing the access token and its secret. At the bottom left, there is a checkbox labeled "ログイン状態を保存" (Save login state). At the bottom right, there is a blue "OK" button.

発行されたシングルサーバAPIキーのアクセストークン、アクセストークンシークレットの組を入力してログイン

3.2.1 リソースのセキュリティ

ログの取得と保管

ログの取得と保管

検討にあたっての考慮事項

- クラウド上でサーバやネットワークを運用するにあたり、不正アクセスやウィルス感染等のセキュリティインシデントが発生した際に、各リソースの調査および分析が出来るよう、必要なログを取得し、適切な期間保管する
- さくらのクラウドでは、標準でイベントログが取得される。また、一部のリソースではログ表示機能やsyslog転送機能が提供されているため、利用を検討する

コントロールパネルとAPIの操作ログ

イベントログについて

- **コントロールパネルとAPIの操作履歴、およびログイン履歴は、イベントログで確認可能**
 - イベントログでは、リソース操作の履歴を確認できる
 - 各操作には、ソースIPアドレスと共に実行日時が記録される
- **イベントログに記録されるイベントの種類は、クラウドマニュアルにて確認することができる**

【Tips】

オートスケールの実行ログ

オートスケール機能を使用する場合は、コントロールパネルの各オートスケール設定の詳細画面にある「ログ」タブを選択すると、オートスケールの実行ログを確認することができます。ローカルPCにファイルとしてダウンロードすることも可能です。

コントロールパネルとAPIの操作ログ

イベントログについて

- イベントログは、コントロールパネルのホーム画面にある「イベントログ」メニューから確認することができる

さくらのクラウド ホーム

マニュアル・サポート情報 お知らせ 障害・メンテナンス

ホーム
プロジェクト
ユーザ
2要素認証
公開鍵
イベントログ
ホストメンテナンス

さくらのクラウド
契約リソース
利用料金管理
APIキー
請求情報
さくらの専用サーバPHY
請求情報
SiteGuard
SendGrid

イベントログ

イベントログを確認できます。詳細は[イベントログのマニュアル](#)をご覧ください。

期間 2025-04-23 ~ 2025-05-23

条件をリセット 絞り込む

詳細な絞り込み条件を表示

全61件中 1~20件 表示中 CSVのダウンロード

日時	認証方法	接続元	ゾーン	ログ種別	内容
2025-05-22 (木) 14:06:50	-	-	-	起動	起動完了
2025-05-22 (木) 14:06:31	-	-	-	利用開始	作成完了
2025-05-22 (木) 14:06:30	-	-	-	利用開始	作成完了
2025-05-22 (木) 14:06:28	-	-	-	タスク完了	-
2025-05-22 (木) 14:05:51	-	-	-	タスク開始	-
2025-05-22 (木) 14:01:53	-	-	-	シャットダウン	シャットダウン完了

コントロールパネルとAPIの操作ログ

イベントログの保管

- イベントログで確認できる履歴は過去一年間分のみ。それよりも前のログを保持したい場合は、利用者がCSV形式で保存する必要がある。以下を考慮して運用を検討する
 - 「CSVに保存」ボタンをクリックすると、検索結果を反映したCSVファイルをローカルPCに保存することができる
 - CSVでダウンロードできるイベントログの件数は最大で1000件

ネットワークのログ

VPNルータのログ表示機能について

- VPNルータのログ表示機能を利用すると、VPN、ファイアウォール、セッション統計情報のログを取得することができる
- VPNルータに記録されているログのうち、コントロールパネル上で確認できるのは最新の100件のみ。VPNルータのログを永続的に保管したい場合には、syslog転送機能を使用する

ネットワークのログ

VPNルータのファイアウォールログ

- ファイアウォールのログに関しては、ログ記録が有効化されたルールにマッチした通信がロギングの対象となる。不必要に大量のログを取得すると、必要な情報の検索や抽出の効率が低下することがある。また、syslog転送時にはログの保存によってストレージの利用率が増加するため、これらを考慮して必要なログのみを取得することを検討する

サーバのログ

サーバのログ取得と保管

- サーバのOSについては利用者の責任範囲となるため、サーバ内部で記録されるログはさくらインターネットから提供されないことを念頭に、利用者側の責任で取得および保管する必要がある



利用者の責任範囲

さくらインターネットの責任範囲

サーバのログ

- **利用するパブリックアーカイブの仕様を確認した上で、サーバのOSに必要なログを取得し、保管するように設定する**
 - パブリックアーカイブから作成したサーバには、OSの標準設定により、初期設定で取得されるログが存在する
 - 一般的に、セキュリティに関するOS上のログとして、監査ログやセキュリティログの取得を検討する

サーバのログ

サーバのアクセスログ

- **サーバへのアクセスログとして、接続元であるクライアントの情報をサーバ側のログとして取得することを検討する**
 - 通常、OSへのリモートログインに関するログや、WebサーバへのHTTPアクセスに関するログでは、接続元の情報を記録し、管理者が確認できるようにする

【Tips】

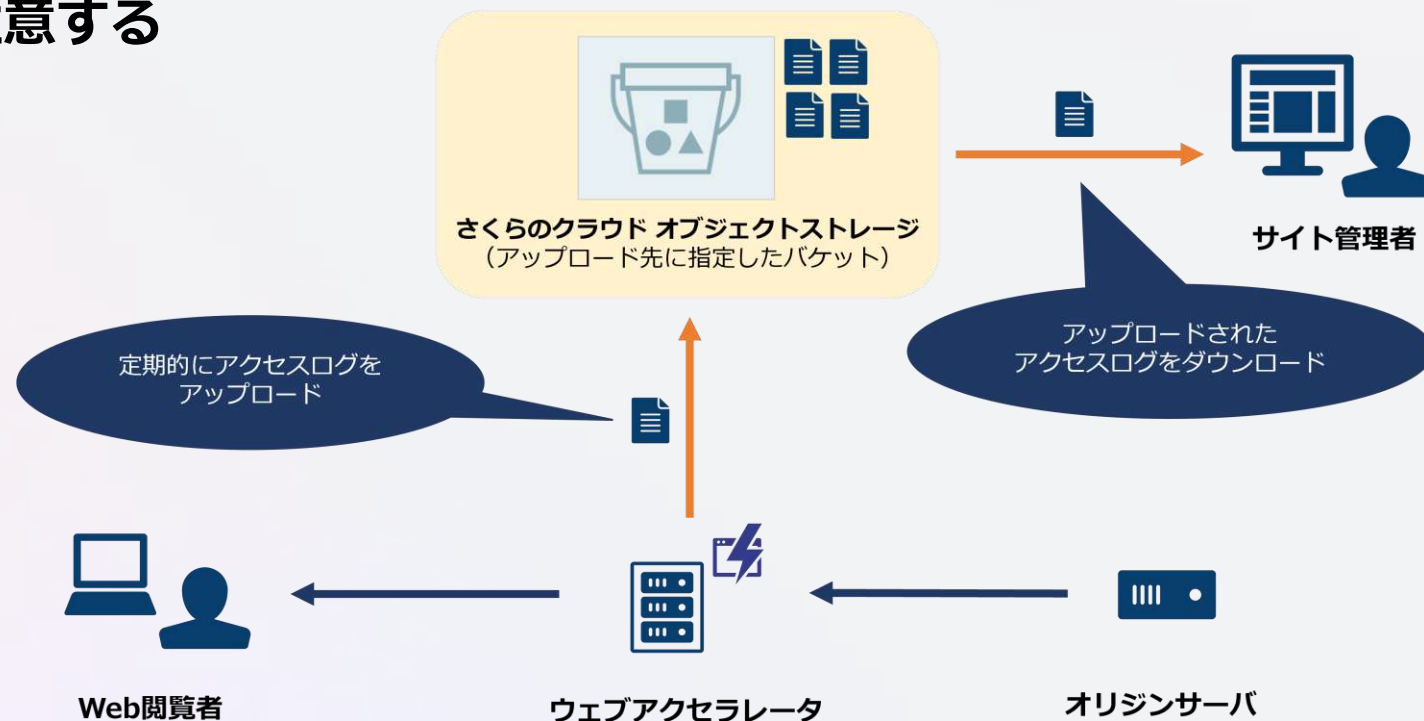
HTTPヘッダを用いた接続元情報の記録について

エンハンスドロードバランサを使用する場合、実サーバへのプロキシ時にHTTPヘッダが付加されます。また、ウェブアクセラレータを利用する場合は、ウェブアクセラレータからオリジンサーバへの接続時にリクエストヘッダが付与されます。これらのヘッダ情報を実サーバ、またはオリジンサーバ側のアクセスログに出力させるように設定し、接続元IPアドレス等を記録することを検討しましょう。

コンテンツ配信のログ

ウェブアクセラレータのアクセスログ

- ユーザーからのリクエスト内容や応答ステータスなどを記録したアクセスログを、指定先のオブジェクトストレージに定期的に自動アップロードすることができる
- アクセスログが外部に公開されないように、アップロード先のオブジェクトストレージの権限設定に注意する



3.2.1 リソースのセキュリティ

サーバアクセス手段の検討

サーバアクセス手段の検討

検討にあたっての考慮事項

- 悪意のある第三者により通信を盗聴されるリスクを考慮して、サーバへのアクセス手段を選択する
- ネットワーク経由でサーバにリモートアクセスする際には、SSHやRDPを用いた暗号化通信の利用を検討する。また、SSH接続するにあたり公開鍵認証を利用してセキュリティレベルを高める
- さくらのクラウドでは、サーバにリモート接続せずに、コンソール接続を使ってウェブブラウザから直接OSを操作することができる

サーバアクセス手段の検討

検討にあたっての考慮事項

【Tips】

サーバ作成後の不正アクセスに備える

サーバを作成し起動した直後は、OSのセキュリティ設定がまだ不十分なために、不正アクセスのリスクが高まることがあります。サーバ作成時、またはサーバ作成後の起動前にパケットフィルタを適用すると、あらかじめ不要なポートを閉塞したり、アクセス元のネットワークを制限した状態でサーバを起動することができます。

公開鍵認証

公開鍵認証について

- 公開鍵認証は、安全なリモート接続のために用いる。公開鍵をサーバに置き、クライアント側には秘密鍵を用意する認証方式で、パスワードを使わずに安全なログインができる
- 公開鍵認証は、辞書攻撃などによる不正ログインのリスクがあるパスワード認証方式とは異なり、秘密鍵が盗まれない限り、認証を突破されるリスクが大幅に低減される

公開鍵認証

公開鍵の管理

- コントロールパネルのホーム画面の「公開鍵」メニューにて、利用者の公開鍵を管理することができる
 - サーバ作成時、登録された公開鍵を指定して、自動的にサーバ内に設置することができる

さくらのクラウド ホーム

公開鍵作成

公開鍵を作成できます。詳細は[公開鍵認証のマニュアル](#)をご覧ください。

プロジェクト	
公開鍵名	プロジェクト用公開鍵 1~64文字で入力してください。
説明	公開鍵の説明 1~512文字で入力してください。
公開鍵	ssh-ed25519 ...

公開鍵認証

公開鍵の管理

- サーバ作成、ディスク追加、ディスク修正時の「公開鍵」ラジオボタンで、事前に登録した公開鍵を選択することができる
 - 「パスワード/チャレンジレスポンスでのSSHログインを許可しない」を有効化した状態でサーバを作成すると、SSHの認証方式は公開鍵認証のみとなる
 - ユーザがGitHubに登録しているSSH公開鍵を選択することも可能

【本スライドについてのご案内】

本スライドは、さくらインターネット株式会社により

[CC BY-SA 4.0ライセンス](https://creativecommons.org/licenses/by-sa/4.0/)で提供されています。

ライセンスの条件に従う限り、自由に再利用いただけますので、ぜひご活用ください。

※ 本スライドに、スライドのタイトル・著作権表示・無保証を参照する表示はありません。

※ 「制作協力：アイティーエム株式会社」「制作協力：株式会社 zero to one」との表記につきましては、クレジットとして表示していただく必要はございません。（表示していただくことも問題ございません。）



教材制作・提供：さくらインターネット株式会社

制作協力：アイティーエム株式会社

制作協力：株式会社 zero to one

【クレジット表示について】

スライドを改変せずに再利用する場合

1. 本スライドの各ページには、再利用する場合に必要な次のクレジットが予め表示されています。

This slide is licensed under [CC BY-SA 4.0](https://creativecommons.org/licenses/by-sa/4.0/) by SAKURA internet Inc.

※ 本スライドの全部をそのままお使いになる場合（本スライドのPDFファイルをそのまま再配布される場合等）や、本スライドの一部の再利用であってもクレジット表示のなされているページをそのままお使いになる場合には、重ねて同じ表示をしていただく必要はありません。

2. 印刷して再利用する場合や画像形式に変換して再利用する場合など、リンクを貼ることができない場合には、ライセンス内容が記載された次のURLをご掲載いただくか、本ページも併せてご印刷・ご掲載ください。

<https://creativecommons.org/licenses/by-sa/4.0/deed.ja>

3. 和文でクレジット表示をなされる方は、次の表示例をご参考にしてください。

本スライドは、さくらインターネット株式会社により[CC BY-SA 4.0ライセンス](https://creativecommons.org/licenses/by-sa/4.0/)で提供されています。

★上記のクレジットに加えて、合理的に実施可能な場合には、本スライドのURLか本スライドへのリンクをご掲載ください。

【クレジット表示について】

スライドを改変の上で再利用する場合

1. 改変の上で再利用される場合、次の表示例をご参考にしてください。

This [slide or document] is adapted from the slide by SAKURA internet Inc.
The slide is licensed under [CC BY-SA 4.0](#).
This [slide or document] is licensed under [CC BY-SA 4.0](#) by [Your name here].

2. 和文でクレジット表示をなされる方は、次の表示例をご参考にしてください。

本[スライド・資料等]は、さくらインターネット株式会社制作のスライドを改変の上利用しています。
同スライドは、[CC BY-SA 4.0ライセンス](#)で提供されています。
本[スライド・資料等]は、[スライド・資料等の制作者の氏名・名称]により[CC BY-SA 4.0ライセンス](#)で提供されています。

★上記のクレジットに加えて、合理的に実施可能な場合には、本スライドのURLか本スライドへのリンクをご掲載ください。